ONE-PAGE BRIEF

Post-quantum cryptography review: bitbox02-firmware @ ae548ef4e40f

Client: BitBox (Shift Crypto) — public repository (passive review) · Source: github.com/BitBoxSwiss/bitbox02-firmware, commit `ae548ef4e40f` · Reviewed: 2026-11-04 20:03 UTC · Risk profile: Crypto exchange, custodian or wallet

POST-QUANTUM MATURITY
Level 0 of 4
no post-quantum cryptography

FINDINGS
1 Critical **11** High **58** Medium
3 Low **6** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)
Key establishment: 10 + 5 − 8 = 7 → **too late**
Signatures: 10 + 5 − 8 = 7 → **too late**

Next step: Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

WHAT MATTERS MOST

Critical QSI-2026-13201	**certifi 2022.12.7 is affected by GHSA-6q48-6c7w-9gw2 (PYSEC-2026-4320)** What to do: Upgrade to a fixed version (2026.10.18).
High QSI-2026-13177	**TLS certificate verification disabled in scripts/generate_version_headers.py** What to do: Remove the override; use a proper CA bundle or pinning.
High QSI-2026-13202	**certifi 2022.12.7 is affected by GHSA-xqr8-7jwr-rhp7 (CVE-2023-37920, PYSEC-2023-135)** What to do: Upgrade to a fixed version (2023.7.22).
High QSI-2026-13206	**jinja2 3.1.2 is affected by GHSA-gmj6-6f8f-6699 (CVE-2024-56201, PYSEC-2026-1472)** What to do: Upgrade to a fixed version (3.1.5).

69 more in the full report.

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium firmware and boot verification (root of trust)	ECDSA	Plan a hybrid firmware signature (the classical one plus ML-DSA or SLH-DSA, both required) and the path to...
Medium key wrapping and data encryption at rest	ECDH, X25519	Wrap keys with ML-KEM or a hybrid KEM (X25519 + ML-KEM-768) and re-wrap the stored keys; data that may...
Medium channel key exchange (TLS, Noise, handshakes)	X25519	Move the handshake to a hybrid key exchange (X25519MLKEM768 in TLS 1.3; a hybrid KEM in Noise-based protocols)
Medium transaction and message signing	ECDSA, Ed25519, Schnorr (BIP-340)	Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum...

KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 32; unlikely to apply to this build: 4 (a Cargo feature that is off, affected functions not named in the code, or a platform that is not built); to review: 28.

Analyst review: 15 confirmed, 5 not applicable, 0 dismissed as false positives. (QSI review, 2026-10-28)

Static review of source code and manifests; files analysed: 2645. No requests were sent to the owner's systems.

Full report, content SHA-256: `d8111e17ce0bc5b8deff8f7f7a9b60c719df8e477293a2b55110061fb7a8136c`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.